

Universidad Peruana
Cayetano Heredia

CARRERA DE INGENIERÍA INFORMÁTICA

Curso: SISTEMAS OPERATIVOS

Integrantes:

- Paloma Fernanda Velasquez (60921203)
- Daniel Fabricio Oliva Moscoso (73710164)
- Alex Jhosep Ccoyllo Sotelo (3476409)
- Jeral Alexander Cueva Zapata (74140816)
- Sofía Dayana Calva Becerra (60239714)
- Rosita Dayana Espinola Abanto (60825993)

Grupo: 5
Profesor: Roberto Eduardo Burga Montañez
Semestre académico: 2026-2

Actividad 1: Análisis de Amenazas de Seguridad

Objetivo: Identificar amenazas y objetivos de seguridad en un entorno organizacional.

Modalidad: Grupal

Instrucciones:

1. Analicen el caso de una empresa que almacena información confidencial de clientes.
2. Identifiquen al menos:
    - 5 amenazas potenciales.
    - Los activos de información afectados.
    - Los objetivos de seguridad comprometidos (confidencialidad, integridad y disponibilidad).
3. Elaboren una matriz de riesgos.

Empresa : Banco Internacional del Perú S.A.A. – Interbank

Es una entidad financiera peruana que almacena y procesa información sensible de sus clientes. En su propia política de privacidad, Interbank señala que mantiene un banco de datos personales denominado “Clientes”, inscrito en el Registro Nacional de Protección de Datos Personales con el código 246. También registra información de videovigilancia y control de accesos.

La propia entidad establece que la ciberseguridad forma parte de su gobierno corporativo y declara como prioridad preservar la confidencialidad, disponibilidad e integridad de la información utilizada en sus canales y servicios.

Por ello, entre sus principales activos de información podemos considerar datos personales de clientes, información financiera, saldos y movimientos de cuentas, credenciales de acceso y los sistemas que permiten operar mediante sus canales digitales.

Amenazas:

- Exposición o filtración de información
- Fallas en los sistemas
- Errores operativos en saldos o en las transacciones
- Malware o troyanos de acceso remoto
- Acceso no autorizado a las cuentas

Amenaza	Activo afectado	Impacto	Objetivo comprometido
Exposición o filtración de información	Datos personales y financieros de los clientes	Alto	Confidencialidad

Falla de los sistemas	Aplicación, banca por Internet y servicios bancarios	Alto	Disponibilidad
Errores operativos en saldos o transacciones	Saldos, movimientos y registros de cuentas	Alto	Integridad y disponibilidad
Malware o troyanos de acceso remoto	Credenciales, dispositivos y cuentas de clientes	Alto	Confidencialidad e integridad
Acceso no autorizado a las cuentas	Credenciales, cuentas e información personal	Alto	Confidencialidad e integridad

Actividad 2: Detección de Accesos No Autorizados

Objetivo: Reconocer diferentes tipos de ataques informáticos.

Instrucciones:

Clasifique cada situación según corresponda:

SITUACIÓN	TIPO DE ATAQUE
Un usuario prueba miles de contraseñas automáticamente.	Ataque de fuerza bruta
Se recibe un correo falso solicitando credenciales.	Phishing
Un programa captura las teclas pulsadas.	Keylogger (registro de pulsaciones del teclado)
Se interceptan datos durante una transmisión.	Ataque de Intermediario (MITM)

Preguntas de reflexión:

- ¿Qué ataque considera más peligroso para una universidad?

  Considero que el Phishing es uno de los ataques más peligrosos para una universidad, porque puede engañar a estudiantes, profesores y trabajadores para que entreguen sus credenciales y así poder acceder a información personal, notas académicas, correos institucionales y datos confidenciales.

- ¿Qué medidas de prevención propondría?

★ Usar contraseñas seguras: Crear contraseñas largas y diferentes para cada cuenta.
★ Activar la autenticación multifactor (MFA): Añadir una segunda verificación para ingresar a las cuentas.
★ Capacitar a los usuarios: Enseñar a reconocer correos falsos y enlaces sospechosos.
★ Proteger las conexiones: Utilizar conexiones cifradas mediante HTTPS y redes

seguras.
★ Monitorear los accesos: Detectar intentos repetidos de inicio de sesión y bloquear actividades sospechosas.

Actividad 3: Diseño de una Política de Seguridad

Objetivo: Aplicar conceptos de políticas y mecanismos de seguridad.

Modalidad: Grupal

Instrucciones:

Diseñen una política de seguridad para el laboratorio de informática de una universidad.

Debe incluir:

- Gestión de contraseñas.
- Uso de dispositivos USB.
- Acceso a internet.
- Respaldo de información.
- Sanciones por incumplimiento.

Producto esperado:

Documento de máximo 2 páginas.

Tiempo: 40 minutos.

Política de Seguridad de la Información: Laboratorio de Informática

Entidad: Universidad — Laboratorio de Informática

Código: PSI-LAB-01

Versión: 1.0

Alcance: Estudiantes, docentes, personal administrativo y personal técnico que hagan uso de las instalaciones, equipos y red del laboratorio.

1. Objetivos y Alcance

Establecer las directrices obligatorias para garantizar la confidencialidad, integridad y disponibilidad de los recursos tecnológicos del laboratorio de informática, minimizando riesgos de malware, fugas de información, accesos no autorizados y daños a la infraestructura.

2. Gestión de Contraseñas y Autenticación

1. **Identificación Única:** Todo usuario debe autenticarse con su cuenta institucional personal. Queda estrictamente prohibido compartir credenciales o utilizar cuentas genéricas para tareas administrativas.
2. **Requisitos de Complejidad:**
    - Longitud mínima de **12 caracteres**.
    - Debe incluir combinación de mayúsculas, minúsculas, números y caracteres especiales (`@`, `#`, `$`, `%`, etc.).
    - No debe contener nombres propios, códigos de estudiante ni palabras comunes del diccionario.
3. **Cierre de Sesión:** Es obligatorio cerrar la sesión de la cuenta institucional y bloquear el equipo al retirarse del puesto de trabajo o estudio, aunque sea por lapsos breves.
4. **Expiración y Almacenamiento:** Las contraseñas deben renovarse cada **90 días**. Queda prohibido anotar contraseñas en notas adhesivas, cuadernos o guardarlas en texto plano en los equipos del laboratorio.

3. Uso de Dispositivos de Almacenamiento Extraíble (USB)

1. **Escaneo Obligatorio:** Todo dispositivo extraíble (Memorias USB, discos duros externos, tarjetas SD) debe ser analizado por el antivirus centralizado del equipo antes de abrir o transferir cualquier archivo.
2. **Restricción de Ejecución:** Queda bloqueada la ejecución automática (*Autoplay/Autorun*) en todas las estaciones de trabajo del laboratorio.
3. **Prohibición de Software No Autorizado:** No se permite la copia ni ejecución de archivos `.exe`, `.bat`, `.sh` o ejecutables no autorizados desde memorias USB hacia los discos locales de los equipos.
4. **Cifrado de Datos Sensibles:** La información confidencial o de proyectos de investigación que se transporte en USB debe estar debidamente cifrada.

4. Control de Acceso a Internet y Red

1. **Uso Exclusivo Académico:** La conexión a Internet del laboratorio está destinada únicamente a actividades académicas, de investigación y docencia.
2. **Filtrado de Contenido:** Se mantendrá un sistema de filtrado web activo para bloquear:
    - Sitios de descarga no oficial o redes P2P (Torrent).
    - Contenido explícito, sitios de apuestas y juegos en línea.
    - Páginas identificadas con phishing, malware o reputación sospechosa.
3. **Descarga de Archivos:** La descarga de programas, ejecutable o controladores está restringida exclusivamente al personal técnico del laboratorio.
4. **Prohibición de Herramientas de Evasión:** Queda estrictamente prohibido el uso o instalación de redes privadas virtuales (VPN), proxies no autorizados o navegadores TOR para eludir los controles de seguridad de la red universitaria.

5. Respaldo y Copias de Seguridad (Backup)

1. **Responsabilidad del Usuario:** Los discos duros locales de las computadoras del laboratorio son de almacenamiento temporal. El laboratorio **no se hace responsable** de la pérdida de archivos guardados localmente.

2. **Uso de Almacenamiento en la Nube:** Los estudiantes y docentes deben guardar y respaldar sus trabajos en sus cuentas institucionales de almacenamiento en la nube (Google Drive / OneDrive institucional).
3. **Respaldos de Servidores e Imágenes de Sistema:**
    - El equipo de TI realizará un respaldo semanal automatizado de las configuraciones y servidores del laboratorio.
    - Se mantendrán imágenes de disco "limpias" para restaurar las estaciones de trabajo periódicamente o tras detectar infecciones por malware.

6. Sanciones por Incumplimiento

El incumplimiento de las normas establecidas en esta política dará lugar a las siguientes sanciones, según la gravedad de la falta:

Nivel de Falta	Ejemplo de Infracción	Sanción Aplicable
Leve	No cerrar sesión; intento de acceso a sitios web no académicos bloqueados.	Amonestación verbal y registro en la bitácora del laboratorio.
Grave	Compartir credenciales; conectar USBs infectados a sabiendas; intentar eludir el filtro de red mediante VPN/Proxy.	Suspensión del acceso al laboratorio de **1 a 4 semanas** y notificación a la dirección académica.
Muy grave	Instalación intencional de malware/keyloggers; alteración del hardware; acceso no autorizado a cuentas de terceros o servidores.	Suspensión total de los servicios informáticos de la universidad, proceso disciplinario universitario y eventuales acciones legales.

Aprobado por: Jefatura de Tecnologías de la Información y Dirección Académica.

Fecha de aplicación: Inmediata.

Actividad 4: Taller de Autenticación y Validación

Objetivo: Comprender mecanismos de validación y autenticación.

Modalidad: Parejas

Instrucciones:

Investiguen y comparen:

1. Contraseña tradicional.
2. Doble factor de autenticación (2FA).
3. Biometría.
4. Tokens de seguridad.

Completen la siguiente tabla:

Método Nivel de seguridad Ventajas Desventajas

Discusión final:

¿Cuál método sería más adecuado para una entidad financiera?

Tiempo: 25 minutos.

Método	Nivel de seguridad	Ventajas	Desventajas
Contraseña tradicional	Bajo	Fácil de implementar y de usar. Costo casi nulo. Todos los usuarios la conocen.	Vulnerable a phishing, fuerza bruta, filtraciones y keyloggers. Los usuarios las reutilizan o las olvidan. Si se roba, el atacante accede sin más barreras.
Doble factor (2FA)	Medio-alto	Combina dos factores (algo que sabes + algo que tienes). Aunque roben la contraseña, falta el segundo factor. Es económico y se usa mucho (SMS, apps como Google Authenticator).	Los SMS pueden interceptarse (SIM swapping). Depende del celular del usuario (pérdida, batería, cobertura). Añade un paso extra al ingreso.
Biometría	Alto	No hay nada que recordar ni que perder. Es difícil de copiar o compartir. Muy cómoda (huella, rostro, iris).	Los datos biométricos no se pueden cambiar si se filtran. Hay falsos positivos y negativos. Plantea riesgos de privacidad y requiere hardware especial.
Tokens de seguridad	Muy alto	Generan códigos únicos o usan criptografía (físicos como YubiKey o tokens OTP). Resisten el phishing, sobre todo los basados en FIDO2. No dependen de la red.	Costo de compra y distribución. Pueden perderse, dañarse o ser robados. Requieren gestión y reposición.

¿Cuál método sería más adecuado para una entidad financiera?

Ningún método por sí solo es suficiente. Lo más adecuado para una entidad financiera es **una autenticación multifactor que combine tokens de seguridad con biometría** (o con contraseña, según el caso), porque protege dinero e información sensible y debe cumplir normativas.

Actividad 5: Matriz de Control de Acceso

Objetivo: Aplicar conceptos de protección y control de acceso.

Modalidad: Individual

Caso:

Una universidad posee los siguientes usuarios:

- Administrador
- Docente
- Estudiante

Y los siguientes recursos:

- Sistema académico
- Base de datos de notas
- Plataforma virtual

Tarea:

Diseñe una matriz de permisos utilizando:

- Lectura (L)
- Escritura (E)
- Modificación (M)

Ejemplo:

Usuario **Sistema Académico Notas Plataforma**
Administrador L,E,M L,E,M L,E,M

Tiempo: 25 minutos.

Resolución:

Usuario	Sistema Académico	Base de Datos de Notas	Plataforma Virtual
Administrador	L, E, M	L, E, M	L, E, M
Docente	L	L, E, M*	L, E, M
Estudiante	L	L**	L, E

Observación:

** Solo sobre las notas de sus propios cursos y estudiantes.*
*** Solo sus propias notas.*

Actividad 6: Debate sobre Seguridad Informática

Objetivo: Analizar problemas reales relacionados con la seguridad de la información.

Modalidad: Grupal

Tema de debate:

"¿Las organizaciones deben monitorear permanentemente las actividades digitales de sus trabajadores para garantizar la seguridad de la información?"

Equipos:

- Equipo A: A favor.
- Equipo B: En contra.

Criterios de evaluación:

- Argumentación técnica.
- Uso de conceptos de seguridad.
- Capacidad crítica.

Equipo A – A favor: Las organizaciones sí deberían monitorear las actividades digitales de sus trabajadores porque esto permite detectar accesos no autorizados, filtraciones de información, instalación de malware o modificaciones indebidas en los sistemas. El monitoreo ayuda a proteger la confidencialidad, integridad y disponibilidad de la información, además de generar registros o logs que permiten identificar quién

realizó una acción y cuándo ocurrió. También es especialmente útil frente a amenazas internas, ya que un empleado con acceso legítimo podría utilizarlo de manera inadecuada.

Equipo B – En contra: Las organizaciones no deberían realizar un monitoreo permanente e ilimitado, porque podría afectar la privacidad de los trabajadores y generar nuevos riesgos si la información recopilada es utilizada incorrectamente. Además, vigilar todas las actividades no garantiza por sí solo la seguridad, por lo que debe complementarse con medidas como autenticación, control de acceso, mínimo privilegio, cifrado y antivirus. Una alternativa más equilibrada sería monitorear únicamente actividades relacionadas con recursos sensibles o comportamientos sospechosos, respetando la proporcionalidad entre seguridad y privacidad.

Actividad 7: Caso Integrador

Objetivo: Integrar todos los conceptos desarrollados en la sesión.

Caso:

Una empresa sufrió un incidente de seguridad:

- Un empleado compartió su contraseña.
- Se produjo acceso no autorizado.
- Se alteraron registros financieros.
- No existía autenticación multifactor.

INFORME TÉCNICO: CASO INTEGRADOR DE SEGURIDAD DE LA INFORMACIÓN

1. Introducción

La seguridad de la información busca resguardar los activos de una organización frente a amenazas y accesos indebidos. En este caso, una empresa fue víctima de un incidente tras la divulgación de la contraseña de uno de sus empleados. Esto derivó en un ingreso no autorizado al sistema y en la manipulación de registros financieros. A ello se suma que la compañía no tenía habilitada la autenticación multifactor.

Este informe examina las amenazas y los objetivos de seguridad comprometidos, los mecanismos de protección ausentes, una política de seguridad apropiada y el modelo de control de acceso que la organización podría adoptar.

2. Análisis del incidente

2.1 ¿Qué amenazas se concretaron?

La principal amenaza que se concretó fue el **acceso no autorizado**. Un tercero logró ingresar al sistema usando las credenciales de un empleado que había compartido su contraseña.

Según los fundamentos de seguridad de la información, una amenaza es cualquier situación capaz de aprovechar una vulnerabilidad para dañar los activos. Aquí, la contraseña compartida fue la debilidad que hizo posible el ingreso indebido.

Asimismo, se produjo una amenaza directa contra los datos, ya que los registros financieros fueron alterados. Esta modificación pone en riesgo la precisión y la confiabilidad de la información de la empresa.

Por otro lado, al compartirse la contraseña, se vuelve difícil saber quién ejecutó realmente cada

acción en el sistema. Esto debilita la posibilidad de atribuir responsabilidades de forma individual.

2.2 ¿Qué objetivos de seguridad se vieron afectados?

Confidencialidad: el acceso no autorizado expuso el sistema, con el riesgo de que personas no autorizadas consultaran o divulgaran información reservada.

Integridad: es el objetivo más directamente perjudicado, pues los registros financieros fueron modificados sin autorización. Cualquier cambio de este tipo atenta contra la exactitud y la completitud de los datos.

Rendición de cuentas: también se vio afectada, porque al usarse credenciales compartidas resulta complicado identificar a la persona responsable de una acción.

La **disponibilidad** no se ve comprometida en el caso, ya que no se menciona interrupción ni pérdida de acceso a los sistemas.

3. Mecanismos de protección ausentes

El mecanismo principal que faltaba era una **autenticación más sólida**. La empresa dependía únicamente de una contraseña, la cual además podía ser compartida.

El material indica que una autenticación robusta debe combinar al menos dos de los tres factores disponibles:

1. **Algo que se conoce**, como una contraseña o PIN.
2. **Algo que se posee**, como un token o dispositivo.
3. **Algo que se es**, como una característica biométrica.

Por tanto, la organización debería adoptar autenticación multifactor para que conocer una contraseña no baste para acceder.

Además, convendría implementar mecanismos de **identificación, autenticación, autorización y rendición de cuentas**, que permiten reconocer al usuario, verificar su identidad, definir los recursos a los que puede acceder y registrar sus acciones.

También es necesario **revisar periódicamente los derechos de acceso**, especialmente tras promociones, cambios de funciones o desvinculaciones.

Por último, deben emplearse **registros de auditoría** que documenten la actividad de usuarios, aplicaciones y sistemas, lo que facilita la investigación de incidentes futuros.

4. Política de seguridad propuesta

Se plantea una **Política de Seguridad y Control de Acceso** orientada a proteger la información y prevenir accesos indebidos. Sus componentes serían:

a) Credenciales individuales

Cada empleado debe contar con una cuenta y contraseña propias. Queda prohibido compartirlas.

b) Autenticación multifactor

Para acceder a sistemas con información sensible, como los registros financieros, se exigirá al menos dos factores de autenticación.

c) Contraseñas robustas

Deben ser extensas, complejas y difíciles de adivinar, evitando datos personales o combinaciones obvias.

d) Control de permisos

Cada usuario tendrá solo los privilegios necesarios para su trabajo. Estos se revisarán periódicamente y se ajustarán cuando haya cambios de puesto o salidas de la organización.

e) Registro y auditoría

Las operaciones relevantes quedarán registradas, lo que permitirá detectar actividades sospechosas e investigar incidentes.

f) Capacitación

El personal recibirá formación en seguridad de la información, enfocada en el manejo de contraseñas, los accesos y los riesgos de compartir credenciales.

5. Modelo de control de acceso recomendado

El modelo más apropiado, según los conceptos vistos en la sesión, es la **Matriz de Control de Acceso**. Esta define qué derechos tiene cada sujeto sobre cada objeto o recurso, es decir, qué usuario puede acceder a qué información y qué acciones puede realizar.

Usuario	**Registros financieros**	**Documentos generales**
Administrador	Leer / Escribir	Leer / Escribir
Contador	Leer / Escribir	Leer
Empleado común	Sin acceso	Leer

Así, los trabajadores no tendrían los mismos permisos: quien no necesite modificar registros financieros no debería poder hacerlo.

La matriz puede implementarse mediante **listas de control de acceso (ACL)** o **listas de capacidades**. Las ACL se asocian al objeto e indican qué puede hacer cada sujeto sobre él, mientras que las listas de capacidades se asocian al sujeto e indican sobre qué objetos puede actuar.

En la práctica, esto restringiría el acceso a los registros financieros y reduciría el riesgo de modificaciones no autorizadas.

6. Conclusiones

El incidente se originó principalmente por una deficiencia en el control de acceso: al compartir una contraseña, una persona pudo ingresar sin autorización.

El objetivo más afectado fue la **integridad**, por la alteración de los registros financieros. También se vieron comprometidas la **confidencialidad** por el acceso indebido y la **rendición de cuentas** por el uso compartido de credenciales.

Para prevenir incidentes similares, la empresa debe implementar autenticación multifactor, contraseñas seguras, cuentas individuales, revisiones periódicas de permisos, registros de auditoría y capacitación del personal.

Finalmente, una **Matriz de Control de Acceso** permitiría definir con claridad los permisos de cada usuario sobre los recursos de la organización, reduciendo las posibilidades de accesos o modificaciones no autorizadas.

Preguntas:

- ¿Qué amenazas se materializaron?

  Se materializó principalmente una amenaza de acceso no autorizado, debido a que un empleado compartió su contraseña. Esto permitió que otra persona pudiera ingresar al sistema sin autorización. Además, se produjo una alteración no autorizada de los registros financieros, afectando la información de la empresa.

- ¿Qué objetivos de seguridad fueron afectados?

  Los principales objetivos afectados fueron:

  - Confidencialidad: porque se permitió el acceso a información por parte de una persona no autorizada.
  - Integridad: porque los registros financieros fueron modificados sin autorización.
  - Control y responsabilidad: porque al compartir una contraseña resulta más difícil identificar quién realizó las acciones dentro del sistema.

  La integridad es el objetivo más claramente afectado, ya que el caso indica directamente que se alteraron registros financieros.

- ¿Qué mecanismos de protección faltaban?

  Faltaban principalmente:

  - Autenticación multifactor, ya que solo se dependía de una contraseña.
  - Control adecuado de acceso, para determinar qué usuarios pueden acceder a determinados recursos.
  - Credenciales individuales, evitando que los empleados compartan sus contraseñas.
  - Mecanismos de auditoría y registro, para poder identificar las acciones realizadas por los usuarios.
  - Revisión de los permisos de acceso, para asegurar que cada usuario tenga solamente los permisos necesarios.

- ¿Qué política de seguridad propondría?

  Propondría una política de control de acceso y protección de la información que establezca que:

  - Cada empleado debe utilizar una cuenta y contraseña personal.
  - Está prohibido compartir las contraseñas.
  - Se debe utilizar autenticación multifactor para acceder a información importante.
  - Los usuarios deben tener únicamente los permisos necesarios para realizar sus funciones.
  - Los accesos y actividades importantes deben quedar registrados para su posterior revisión.
  - Los permisos deben revisarse periódicamente.

    - Los empleados deben recibir capacitación sobre seguridad y manejo de credenciales.

- ¿Qué modelo de control de acceso sería el más adecuado?

  El más adecuado sería una Matriz de Control de Acceso, porque permite establecer qué usuarios pueden acceder a determinados recursos y qué acciones pueden realizar sobre ellos.

Producto esperado:

Informe técnico de 2 a 3 páginas.

Tiempo: 45 minutos.